

Laporan Teknis Proyek: E-Commerce Jatibahagya (Kompilasi Lengkap)

Mata Kuliah: KOM1315 Keamanan Informasi

Kelompok 6: Taura Mohamad Inzaghi, Muhammad Syafiq Romadhon, Muhammad Fauzan Akbar

Daftar Dokumen (Kompilasi Repositori)

- **Proposal:** 01_Proposal_&_Analisis/Proposal_Teknis.pdf
- **Desain:** 02_Design_Documents/Architecture_Diagram.pdf, 02_Design_Documents/ERD_Modified.png, 02_Design_Documents/Testing_Plan.pdf
- **Manual Penggunaan Fitur Keamanan bagi Administrator:** Terintegrasi pada Bab 3 dokumen ini.
- **Log Pengujian:** 05_Testing/* (hasil pengujian otomatis melalui PHPUnit) dan JIKA_Paper.md (ringkasan hasil uji performa autentikasi plaintext vs enkripsi).

1. Proposal Proyek

1.1 Latar Belakang

Perkembangan teknologi informasi telah mendorong banyak perusahaan untuk melakukan transformasi digital dalam berbagai aspek operasional bisnis, termasuk pemasaran, administrasi, dan pelayanan kepada pelanggan. Jatibahagya merupakan perusahaan yang bergerak di bidang produksi dan penjualan furnitur berbahan kayu jati. Saat ini proses pemasaran dan administrasi pada perusahaan tersebut masih dilakukan secara manual sehingga menimbulkan berbagai kendala, seperti keterbatasan jangkauan pemasaran, pengelolaan data produk yang kurang efisien, serta proses komunikasi dengan pelanggan yang belum terintegrasi secara digital.

Untuk mengatasi permasalahan tersebut, dirancang sebuah aplikasi Jatibahagya WebApp, yaitu platform e-commerce yang memungkinkan perusahaan untuk menampilkan katalog produk, melakukan pengelolaan data produk secara digital, serta memfasilitasi komunikasi antara pelanggan dan pihak perusahaan melalui fitur chat. Mengingat pentingnya keamanan informasi, sistem ini dilengkapi dengan mekanisme enkripsi pada proses autentikasi login serta komunikasi pada fitur chat agar data yang dikirimkan melalui jaringan tetap terlindungi dari ancaman penyadapan maupun manipulasi data.

1.2 Tujuan Proyek

1. Mengembangkan aplikasi web yang dapat digunakan sebagai platform e-commerce untuk memasarkan produk furnitur Jatibahagya secara online.
2. Mempermudah pengelolaan data produk dan administrasi penjualan melalui sistem berbasis web yang terintegrasi.
3. Menyediakan fitur komunikasi antara pengguna dan pihak perusahaan melalui fitur chat

- pada aplikasi.
4. Meningkatkan keamanan sistem dengan menerapkan mekanisme enkripsi pada proses login dan komunikasi chat untuk melindungi data pengguna.
 5. Meningkatkan efisiensi operasional dan memperluas jangkauan pemasaran perusahaan melalui pemanfaatan teknologi digital.

1.3 Ruang Lingkup

- Sistem berupa aplikasi web e-commerce Jatibahagya yang diakses melalui browser.
- Menyediakan fitur registrasi, login, manajemen produk oleh admin, katalog produk, dan fitur chat pengguna-admin.
- Menerapkan mekanisme autentikasi pengguna dan pemisahan hak akses (Role-Based Access Control).
- Keamanan sistem difokuskan pada enkripsi data pada proses login (password hashing) dan enkripsi pesan (AES) pada fitur chat.

2. Desain Sistem dan Keamanan

2.1 Arsitektur Sistem

Sistem dirancang dengan pendekatan layered architecture agar setiap bagian memiliki tanggung jawab yang jelas dan mudah dipelihara. Arsitektur ini terdiri dari empat lapisan utama:

- **Client Layer:** Berisi perangkat pengguna seperti web browser dan mobile browser yang mengakses aplikasi secara aman melalui protokol HTTPS.
- **User Experience Layer:** Antarmuka pengguna yang mencakup halaman publik, halaman pelanggan, dan panel admin berbasis Filament.
- **Middleware / Application Layer:** Logika inti aplikasi berbasis Laravel 11, menangani routing, controller, service, autentikasi (OTP & AAA protocol), validasi, dan antrian (queue jobs).
- **Back-End Resources:** Sumber daya data yang meliputi MySQL Database (18 tabel), file storage untuk gambar produk, Mail Server SMTP (Gmail/Mailtrap) untuk notifikasi, dan IndoRegion API untuk data wilayah.

2.2 Analisis Risiko (Threat Modeling)

- **Brute-force Attack:** Dimitigasi dengan enkripsi password (algoritma Bcrypt dengan 12 rounds), pembatasan jumlah percobaan login (rate limiting), dan penggunaan CAPTCHA.
- **SQL Injection:** Dicegah menggunakan Eloquent ORM dari Laravel yang secara otomatis mengimplementasikan prepared statement dan parameter binding.
- **Session Hijacking:** Diatasi dengan regenerasi Session ID pada saat login, implementasi HTTPS, dan konfigurasi cookie dengan flag HttpOnly serta Secure.
- **Cross-Site Scripting (XSS):** Diminimalisasi melalui validasi input pengguna yang ketat dan sanitasi otomatis pada output HTML menggunakan Blade templating engine.

2.3 Protokol Keamanan

- **Protokol Autentikasi Pengguna:** Memastikan pengguna memvalidasi kredensial yang tersimpan dalam bentuk hash. Sistem akan membuat session ID baru setelah kredensial divalidasi dengan benar.
- **Protokol Reset Password OTP:** Menggunakan Time-Based One-Time Password (OTP) 6 digit yang dikirim via email untuk memverifikasi identitas pengguna sebelum mengizinkan pembaruan password.
- **Protokol Komunikasi Chat:** Pesan yang dikirim melalui koneksi WebSocket disanitasi dari potensi skrip berbahaya, kemudian dienkripsi menggunakan Advanced Encryption Standard (AES) sebelum disimpan ke dalam database, memastikan kerahasiaan komunikasi antara pelanggan dan admin.

3. Manual Penggunaan Fitur Keamanan (Administrator)

Panel administrasi (berbasis Filament 3) merupakan area sangat krusial yang memerlukan protokol akses ketat. Berikut adalah panduan operasional terpadu berdasarkan implementasi fitur keamanan pada repositori.

A. Akses Modul Admin (Filament) & Validasi Multi-Level

1. Login sebagai akun dengan role **admin** dengan menavigasi ke URL aman /admin melalui koneksi HTTPS.
2. Masukkan kredensial email dan kata sandi. Sistem akan melakukan pengecekan ganda (AAA Protocol): memastikan status akun adalah `is_verified = true` dan memeriksa status peran (Role) pada database apakah diizinkan untuk mengakses modul Filament.
3. Pastikan Anda dapat mengakses resource (mis. User Resource). Validasi yang relevan dapat dilihat pada pengujian Tests\Feature\Admin\AdminAccessTest.php.
4. **Pengelolaan Sesi:** Selalu gunakan tombol **Logout** untuk menghancurkan sesi terenkripsi secara aman saat meninggalkan meja kerja.

B. Manajemen Pengguna (Role & Akses)

Sistem mengimplementasikan prinsip *Least Privilege*. Sebagai administrator:

1. Dari dashboard admin, buka menu **Users** (User Management).
2. Verifikasi bahwa pengguna memiliki field **role** yang sesuai:
 - **super_admin:** Akses penuh terhadap seluruh modul.
 - **staff:** Dibatasi pada manajemen katalog produk dan pembaruan status pengiriman.
 - **customer_support:** Hanya akses ke antarmuka chat terenkripsi dan ulasan/Q&A pelanggan.
3. Kelola status verifikasi pengguna agar fitur akses pengguna sesuai secara real-time.

C. Autentikasi dan Verifikasi OTP

1. Saat registrasi user, sistem otomatis mengirim OTP berbasis waktu (6 digit) ke email pengguna.
2. Admin tidak perlu memasukkan OTP (alur OTP berasal dari user), namun admin dapat memverifikasi dampak status `is_verified` melalui proses login pengguna.

D. Verifikasi Signature Pesanan

1. Buka halaman verifikasi signature (endpoint terkait) pada dashboard admin.
2. Masukkan signature_id dari transaksi terkait.
3. Sistem akan mengembalikan status valid/invalid untuk menjamin *non-repudiation* pesanan.

E. Pemantauan Log Transaksi dan Komunikasi Aman

- **Log Aktivitas (Accounting):** Seluruh perubahan pada data sensitif (seperti perubahan harga atau status pembayaran) dicatat oleh sistem. Pantau log ini secara berkala.
- **Fitur Chat:** Pesan pelanggan yang diterima didekripsi secara otomatis (dari AES) oleh server sesaat sebelum ditampilkan di antarmuka chat. Jangan menyalin informasi sensitif pelanggan ke luar aplikasi.

F. Pengujian Performa (Plaintext vs Enkripsi Payload)

1. Untuk melakukan audit performa mandiri, jalankan test performa dengan filter command:
php artisan test --filter=AuthEncryptionPerformanceTest
2. Hasil uji akan memperlihatkan overhead enkripsi.

4. Log Pengujian Sistem

4.1 Test Suite yang Tersedia di Repositori

Pengujian otomatis dieksekusi menggunakan PHPUnit yang mencakup:

- 05_Testing/Feature/Auth/LoginTest.php
- 05_Testing/Feature/Auth/RegisterTest.php
- 05_Testing/Feature/Social/WishlistReviewQuestionTest.php
- 05_Testing/Feature/Admin/AdminAccessTest.php
- 03_Source_Code/backend/tests/Feature/Auth/AuthEncryptionPerformanceTest.php (Uji performa autentikasi plaintext vs encrypted payload).

4.2 Tabel Skenario Pengujian Fungsional & Keamanan

ID Skenario	Langkah-langkah	Hasil Output	Prioritas
SU-01	Isi nama, email baru, password valid dan konfirmasi sama, phone, address opsional	User berhasil dibuat, password ter-hash, status is_verified bernilai false, OTP dibuat, email OTP dikirim, redirect ke halaman verifikasi	High
SU-02	Registrasi dengan	Validasi gagal, user	High

ID Skenario	Langkah-langkah	Hasil Output	Prioritas
	email yang sama dengan user existing	tidak dibuat	
LI-01	Masukkan email dan password yang benar untuk user dengan is_verified = true	Login berhasil, diarahkan ke /orders	High
LI-02	Masukkan email dan password benar untuk user dengan is_verified = false	Login ditolak karena credential mensyaratkan is_verified = true	High
OTP-01	Masukkan email yang terdaftar dan OTP 6 digit yang benar, belum kedaluwarsa	Akun berhasil diverifikasi, is_verified menjadi true, OTP dihapus, redirect ke login	High
OTP-03	Masukkan OTP yang benar tetapi sudah lewat 30 menit	Validasi gagal, muncul pesan Kode OTP sudah kadaluarsa	High
RP-04	Buka link reset dari email, isi password baru dan konfirmasi benar	Password berhasil diganti, redirect ke halaman login	High
RP-10	Coba reset password akun yang belum verifikasi OTP	Perilaku mengikuti aturan auth aplikasi; jika dibatasi, reset harus gagal atau diarahkan sesuai kebijakan	Medium
ADM-LG-01	Buka /admin, isi email dan password admin yang valid, lalu submit	Admin berhasil login dan masuk ke dashboard Filament	High
ADM-LG-05	Gunakan user role customer untuk login ke /admin	Akses ditolak atau tidak bisa masuk ke dashboard admin	High
PRD-01	Buka halaman produk tanpa filter	Semua produk tampil dengan pagination 8 item per halaman	High

ID Skenario	Langkah-langkah	Hasil Output	Prioritas
PRD-10	Buka detail produk dengan ID yang ada	Detail produk tampil lengkap beserta atribut dan varian	High

**Dokumen ini merupakan hasil kompilasi akhir untuk mendokumentasikan fungsionalitas dan keamanan repositori berjalan E-Commerce Jatibahagya.*